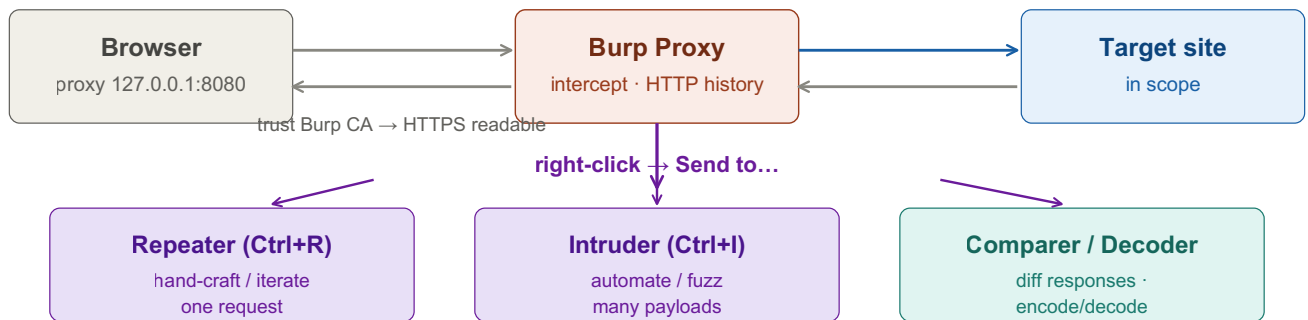


Burp Suite — Overview

The core web-app testing proxy: it sits between your browser and the target so you can intercept, inspect, modify, and replay HTTP(S). This is the setup + workflow hub — see burp-repeater and burp-intruder for the attack tools. Replace <placeholders> with your own values.



The core loop

- 1 · Open Burp browser (proxy + CA already set)
- 2 · Add target to scope · filter history to in-scope
- 3 · Intercept ON to edit live · OFF to browse, review in HTTP history
- 4 · Grab the interesting request → Ctrl+R (Repeater) / Ctrl+I (Intruder)

① Start Burp + the Pre-Configured Browser

The fastest setup: Burp's built-in Chromium already has the proxy and CA trusted.

Tab 1 · Burp

Proxy tab → Intercept → "Open Browser"

Everything you browse in that window flows through Burp automatically — no manual proxy/cert steps.

② Use Your Own Browser (manual)

If you prefer your own browser, point it at Burp's listener and trust the CA.

Tab 2 · Browser setup

```
# proxy listener default
127.0.0.1:8080          (Proxy → Proxy settings)

# set browser/system HTTP+HTTPS proxy to 127.0.0.1:8080
# FoxyProxy extension makes toggling easy

# install Burp's CA so HTTPS is readable:
browse to http://burp → download CA Certificate (cacert.der)
→ import as a trusted Root CA (Firefox: Settings → Certificates → Import)
```

Without the CA, HTTPS sites throw certificate errors and you can't read the traffic.

③ Set Scope Early

Scope keeps noise out and prevents hitting out-of-scope hosts.

Tab 3 · Target

Target → Site map → right-click host → "Add to scope"
Proxy/HTTP history → filter → "Show only in-scope items"
Settings → "Drop out-of-scope requests" (safety)

④ The Core Loop: Intercept ↔ History

Hold requests to edit them live, or let traffic flow and review the log.

Tab 1 · Proxy

Intercept ON → requests pause; edit then Forward / Drop
Intercept OFF → traffic flows; review everything in HTTP history (search + filter)

⑤ Send to the Right Tool (the hub move)

Right-click any request → "Send to ..." to fan it out.

Tab 4 · Send to...

Send to Repeater	(Ctrl+R)	manual tampering / iterate one request
Send to Intruder	(Ctrl+I)	automated fuzzing / many payloads
Send to Comparer		diff two requests or responses
Send to Decoder		encode / decode / hash a value
Send to Organizer		save interesting requests for later

Other tools: Decoder (URL/Base64/hex/hash), Comparer (true/false diffing for blind injection), Sequencer (token randomness), Extensions/BApp Store (Authorize, Logger++, Param Miner, JSON Web Tokens).

Shortcuts & Caveats

Tab 2 · Shortcuts

Ctrl+R	send to Repeater	Ctrl+I	send to Intruder
Ctrl+Shift+B	Base64 selection	Ctrl+Shift+U	URL-decode selection

Community Edition throttles Intruder heavily and has no active scanner. Only test targets you're authorized to test.

Key idea: Burp is a man-in-the-middle for your own browser. You proxy traffic, trust its CA so HTTPS is readable, scope to the target, then capture requests and fan them out to the specialised tools — Repeater to hand-craft, Intruder to automate. Almost every web attack starts by grabbing the right request here and pressing Ctrl+R or Ctrl+I.